RESUMEN DEL ENTORNO

Entorno diseñado como escenario controlado de Pruebas de Penetración (Pentesting) para practicar técnicas de recolección de información y enumeración sobre una plataforma deliberadamente vulnerable.

Descripción de la configuración de Máquina virtual BeeBox:

a.- Objetivo (Target): BeeBox VM

- Entorno: red local / laboratorio
- Objetivo principal: 192.168.1.50 (BeeBox / bWAPP)
- Host adicional observado en enumeración web: 192.168.1.176

Máquina virtual BeeBox, que aloja la aplicación web bWAPP (buggy Web Application) preconfigurada con la modificación de la configuración de Postfix (archivo /etc/postfix/main.cf - ajuste del relayhost para que coincida con mi entorno).

Se trata de una máquina virtual con aplicación web gratuita y de código abierto que es deliberadamente vulnerable, diseñada para ayudar estudiantes a aprender sobre las vulnerabilidades de seguridad web y cómo mitigarlas.

Sistema Operativo: Basado en Linux (Ubuntu personalizado).

Configuración de Red: Configuradas en Modo Puente (Bridged), permitiendo que tanto la víctima (BeeBox) como el atacante (Kali Linux) obtengan direcciones IP en el mismo segmento de la red local, facilitando la comunicación directa.

Estado de la Aplicación: bWAPP está configurado con diferentes niveles de seguridad (Low, Medium, High) para permitir el entrenamiento progresivo en la detección de fallos de seguridad web.

Descripción de la configuración de Máquina virtual Kali Linux:

b.- Máquina Atacante: Kali Linux

Sistema Operativo: Kali Linux, una distribución especializada en auditoría y seguridad informática que contiene preinstaladas las herramientas necesarias para el reconocimiento.

Herramientas Utilizadas:

Para este ejercicio se empleó un conjunto de herramientas "clave" divididas por fases:

- Descubrimiento de hosts: nmap (ping sweep)
- Enumeración de puertos y versiones: nmap (-sV, -p-)
- Fase de reconocimiento / OSINT: nslookup, whois
- Detección de misconfig y hallazgos web: Nikto
- Enumeración de contenido web: gobuster, dirb

RESULTADOS DEL ESCANEO DE RED

Direcciones IP identificadas:

Reconocimiento de Red:

Se realizó un escaneo de red utilizando Nmap sobre el rango **192.168.1.0/24**, con el objetivo de identificar los dispositivos activos en la red local.

Como resultado, se detectaron **8 hosts activos**, siendo la IP .50 el objetivo principal de la auditoría, los cuales se detallan a continuación:

Dirección IP	Estado	Fabricante (MAC)	Observaciones
192.168.1.1	Activo	Askey Computer	Router de la red
192.168.1.49	Activo	Google	Dispositivo IoT / servicio Google
192.168.1.50	Activo	Oracle VirtualBox	⚠ Máquina objetivo (BeeBox)
192.168.1.63	Activo	Amazon Technologies	Dispositivo IoT
192.168.1.91	Activo	Amazon Technologies	Dispositivo IoT
192.168.1.114	Activo	iRobot	Dispositivo doméstico
192.168.1.177	Activo	CyberTAN Technology	Router / repetidor
192.168.1.178	Activo	No identificado	Posible host adicional

RESULTADOS DE ENUMERACIÓN DE SERVICIOS

Puertos y servicios encontrados:

- Descubrimiento de hosts: nmap (ping sweep)

nmap -sn (Network Mapper): Utilizado para el descubrimiento de hosts vivos en la red y la identificación de puertos abiertos y servicios activos en la BeeBox.

```bash
nmap -sn 192.168.1.0/24
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.1.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 04:55 -0400
Nmap scan report for 192.168.1.1
Host is up (0.0051s latency).
MAC Address: D4:7B:B0:37:A6:FF (Askey Computer)
Nmap scan report for 192.168.1.49
Host is up (0.0091s latency).
MAC Address: F0:5C:77:52:3D:3C (Google)
Nmap scan report for 192.168.1.50
Host is up (0.00076s latency).
MAC Address: 08:00:27:AB:C5:2A (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.63
Host is up (0.18s latency).
MAC Address: B0:F7:C4:89:3A:85 (Amazon Technologies)
Nmap scan report for 192.168.1.91
Host is up (0.055s latency).
MAC Address: 5C:8B:6B:51:A3:39 (Amazon Technologies)
Nmap scan report for 192.168.1.114
Host is up (0.19s latency).
MAC Address: 4C:B9:EA:3A:7E:70 (iRobot)
Nmap scan report for 192.168.1.177
Host is up (0.00055s latency).
MAC Address: 28:39:26:53:28:49 (CyberTAN Technology)
Nmap scan report for 192.168.1.178
Host is up.
Nmap done: 256 IP addresses (8 hosts up) scanned in 3.63 seconds
```

Con este comando hemos utilizado la herramienta nmap con -sn (ping scan). Con él conseguimos la información (escaneo) de los puertos abiertos de todo el rango de mi red local sin atacarlos.

- Enumeración de puertos y versiones: Nmap (-sV, -p-)

nmap -sV, -p-: Enumeración de puertos y servicios

```bash
nmap -sV -p- 192.168.1.50
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p- 192.168.1.50
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-06 04:58 -0400
Nmap scan report for 192.168.1.50
Host is up (0.00072s latency).
Not shown: 65516 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         ProFTPD 1.3.1
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
25/tcp   open  smtp        Postfix smtpd
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_fastcgi/2.4.6 PHP/5.2.4-2ubuntu5
with Suhosin-Patch mod_ssl/2.2.8 OpenSSL/0.9.8g)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: ITSECGAMES)
443/tcp  open  ssl/http    Apache httpd 2.2.8 ((Ubuntu) DAV/2 mod_fastcgi/2.4.6 PHP/5.2.4-
2ubuntu5 with Suhosin-Patch mod_ssl/2.2.8 OpenSSL/0.9.8g)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: ITSECGAMES)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell?
666/tcp  open  doom?
3306/tcp open  mysql       MySQL 5.0.96-0ubuntu3
3632/tcp open  distccd     distccd v1 ((GNU) 4.2.3 (Ubuntu 4.2.3-2ubuntu7))
5901/tcp open  vnc         VNC (protocol 3.8)
6001/tcp open  X11         (access denied)
8080/tcp open  http        nginx 1.4.0
8443/tcp open  ssl/http    nginx 1.4.0
9080/tcp open  http        lighttpd 1.4.19
9443/tcp open  ssl/http    lighttpd 1.4.19
1 service unrecognized despite returning data. If you know the service/version, please submit the
following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port666-TCP:V=7.98%I=7%D=4/6%Time=69D375E2%P=x86_64-pc-linux-gnu%r(Gene
SF:ricLines,400,"\*\*\*\x20bWAPP\x20Movie\x20Service\x20\*\*\*\nMatching\x
SF:20movies:\x200\n\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0
SF:\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0
SF:\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0
SF:\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0
SF:\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0
SF:\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0
SF:\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0
SF:\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0
```

```
SF:\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0
SF:\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0
SF:\0\0\0\0\0\0\0\0\0")%r(beast2,400,"\*\*\*\x20bWAPP\x20Movie\x20Service\
SF:x20\*\*\*\nMatching\x20movies:\x200\n\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\
SF:0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0\0
```

Puerto	Estado	Servicio	Versión / Notas
666/tcp	open	doom?	Fingerprint sugiere "bWAPP Movie Service"
3306/tcp	open	mysql	MySQL 5.0.96
3632/tcp	open	distccd	distccd v1 ((GNU) 4.2.3)
5901/tcp	open	vnc	VNC (protocol 3.8)
6001/tcp	open	X11	Access denied
8080/tcp	open	http	nginx 1.4.0
8443/tcp	open	ssl/http	nginx 1.4.0
9080/tcp	open	http	lighttpd 1.4.19
9443/tcp	open	ssl/http	lighttpd 1.4.19

El análisis de puertos revela múltiples servicios expuestos, muchos de ellos con versiones obsoletas. Destaca especialmente el uso de Apache 2.2.8 y PHP 5.2, ambos conocidos por contener vulnerabilidades críticas. Además, la presencia de servicios como FTP, SMB, MySQL y VNC incrementa significativamente la superficie de ataque.

INFORMACIÓN DEL DOMINIO

- Fase de reconocimiento / OSINT: nslookup, whois, sublist3r.

Resultados de nslookup y whois:

Recolección de Información sobre el dominio: nslookup, whois. Con ello pretendemos obtener detalles técnicos del direccionamiento y registros asociados a la IP del objetivo.

nslookup:

```
bash
nslookup 192.168.1.50
```

```
┌──(kali㉿kali)-[~]
└─$ nslookup 192.168.1.50
** server can't find 50.1.168.192.in-addr.arpa: NXDOMAIN
```

Al ejecutar el comando nslookup sobre la dirección IP objetivo, no se obtuvo un nombre de dominio asociado, devolviendo el error NXDOMAIN. Esto es debido a que la máquina se encuentra en una red privada (192.168.0.0/16) sin configuración de resolución DNS inversa, lo cual es habitual en entornos de laboratorio.

whois:

```bash
whois 192.168.1.50
```

```
┌──(kali㉿kali)-[~]
└─$ whois 192.168.1.50

#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2026, American Registry for Internet Numbers, Ltd.
#


NetRange:       192.168.0.0 - 192.168.255.255
CIDR:           192.168.0.0/16
NetName:        PRIVATE-ADDRESS-CBLK-RFC1918-IANA-RESERVED
NetHandle:      NET-192-168-0-0-1
Parent:         NET192 (NET-192-0-0-0-0)
NetType:        IANA Special Use
OriginAS:
Organization:   Internet Assigned Numbers Authority (IANA)
RegDate:        1994-03-15
Updated:        2024-05-24
Comment:        These addresses are in use by many millions of independently operated
networks, which might be as small as a single computer connected to a home gateway,
and are automatically configured in hundreds of millions of devices.  They are only
intended for use within a private context  and traffic that needs to cross the
Internet will need to use a different, unique address.
Comment:
Comment:        These addresses can be used by anyone without any need to coordinate
with IANA or an Internet registry.  The traffic from these addresses does not come
from ICANN or IANA.  We are not the source of activity you may see on logs or in e-
mail records.  Please refer to http://www.iana.org/abuse/answers
Comment:
Comment:        These addresses were assigned by the IETF, the organization that
develops Internet protocols, in the Best Current Practice document, RFC 1918 which
can be found at:
Comment:        http://datatracker.ietf.org/doc/rfc1918
Ref:            https://rdap.arin.net/registry/ip/192.168.0.0



OrgName:        Internet Assigned Numbers Authority
OrgId:          IANA
Address:        12025 Waterfront Drive
Address:        Suite 300
City:           Los Angeles
StateProv:      CA
PostalCode:     90292
Country:        US
RegDate:
Updated:        2024-05-24
Ref:            https://rdap.arin.net/registry/entity/IANA


OrgTechHandle: IANA-IP-ARIN
```

```
OrgTechName:   ICANN
OrgTechPhone:  +1-310-301-5820
OrgTechEmail:  abuse@iana.org
OrgTechRef:    https://rdap.arin.net/registry/entity/IANA-IP-ARIN

OrgAbuseHandle: IANA-IP-ARIN
OrgAbuseName:   ICANN
OrgAbusePhone:  +1-310-301-5820
OrgAbuseEmail:  abuse@iana.org
OrgAbuseRef:    https://rdap.arin.net/registry/entity/IANA-IP-ARIN


#
# ARIN WHOIS data and services are subject to the Terms of Use
# available at: https://www.arin.net/resources/registry/whois/tou/
#
# If you see inaccuracies in the results, please report at
# https://www.arin.net/resources/registry/whois/inaccuracy_reporting/
#
# Copyright 1997-2026, American Registry for Internet Numbers, Ltd.
#


┌──(kali㉿kali)-[~]
└─$
```

Con este comando, vemos que nos da una serie de información de organizaciones, dominios, email dentro del rango de IP 192.168.0.0 – 192.168.255.255. La dirección IP pertenece a un rango privado (192.168.0.0/16), lo que indica que el entorno es local y no accesible desde Internet.

SUBDOMINIOS ENCONTRADOS

Resultados de sublist3r:

sublist3r: Para la enumeración de subdominios.

```
bash
sublist3r -d ?.com
```

```
┌──(kali㉿kali)-[~]
└─$ sublist3r -d bee-box.local

             ____        _   _ _   _  _____
            / ___| _   _| |__ | (_)___| |_|___ / _ __
            \___ \| | | | '_ \| | / __| __| |_ \| '__|
             ___) | |_| | |_) | | \__ \ |_ ___) | |
            |____/ \__,_|_.__/|_|_|___/\__|____/|_|

            # Coded By Ahmed Aboul-Ela - @aboul3la
```

```
[-] Enumerating subdomains now for bee-box.local
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSdumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[!] Error: Virustotal probably now is blocking our requests
[!] DNSDumpster module failed: Could not find CSRF token on DNSDumpster page
```

No fue posible realizar enumeración de subdominios, ya que el objetivo utiliza una dirección IP local sin dominio asociado. Debido a que la infraestructura es local y no está registrada en un DNS público, la herramienta no puede recuperar registros de motores de búsqueda.

VULNERABILIDADES IDENTIFICADAS

Resultados de nikto:

- Detección de misconfig y hallazgos web: nikto

nikto: Escáner de servidor web que detecta archivos peligrosos, software desactualizado y problemas de configuración específicos.

```bash
nikto -h 192.168.1.50
```

```
┌──(kali㉿kali)-[~]
└─$ nikto -h 192.168.1.50
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          192.168.1.50
+ Target Hostname:    192.168.1.50
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-04-06 08:38:58 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2 mod_fastcgi/2.4.6 PHP/5.2.4-2ubuntu5 with Suhosin-Patch
mod_ssl/2.2.8 OpenSSL/0.9.8g
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 838422, size: 588,
mtime: Sun Nov  2 13:20:24 2014. See: https://cve.mitre.org/cgi-bin/cvename.cgi?
name=CVE-2003-1418
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
```

```
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to
easily brute force file names. The following alternatives for 'index' were found: index.bak, index.html.
See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/
vulnerabilities/8275
+ [600511] mod_ssl/2.2.8 appears to be outdated (current is at least 2.9.6) (may depend on server
version).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5 appears to be outdated (current is at least 8.5.1).
+ [600595] OpenSSL/0.9.8g appears to be outdated (current is at least 3.6.0). OpenSSL 1.1.1w is
current for 1.x and is supported via contract, and 3.0.12 for 3.0.x, and 3.1.4 for 3.1.x.
+ [013587] /: Suggested security header missing: permissions-policy. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See:
https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [800132] /: mod_ssl/2.2.8 OpenSSL/0.9.8g - mod_ssl 2.8.7 and lower are vulnerable to a remote
buffer overflow which may allow a remote shell.
+ [800262] /: PHP/5.2 - PHP 3/4/5 and 7.0 are End of Life products without support.
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to
XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001406] /server-status: The mod_status module reveals Apache information. See:
https://httpd.apache.org/docs/2.4/mod/mod_status.html
+ [999986] /phpmyadmin/changelog.php: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.
+ [001795] /phpmyadmin/changelog.php: phpMyAdmin is for managing MySQL databases, and
should be protected or limited to authorized hosts.
+ [003569] /INSTALL.txt: Default file found.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-
restricting-access-to-iconsreadme/
```

El escaneo realizado con Nikto revela múltiples vulnerabilidades críticas en el servidor web, Apache 2.2.8 (Ubuntu), PHP 5.2.4, OpenSSL 0.9.8g. El servidor web utiliza versiones antiguas de Apache, PHP y OpenSSL, todas ellas fuera de soporte y con múltiples vulnerabilidades conocidas.

Riesgo:

Ejecución remota de código
Escalada de privilegios
Explotación conocida pública

Vulnerabilidades críticas:

– Stack obsoleto y riesgo de RCE. Apache 2.2.8 / PHP 5.2.4 / OpenSSL 0.9.8g y mod_ssl antiguo. La exposición de componentes EOL incrementa significativamente la probabilidad de explotación con vulnerabilidades conocidas.

– Exposición de archivo de credenciales. Nikto reporta /#wp-config.php# como archivo accesible. Este artefacto suele contener credenciales (BD) y secretos.

– Interfaz de administración expuesta. /phpmyadmin/ detectado. Sin restricciones de acceso, habilita ataques directos contra MySQL (fuerza bruta, abuso de sesiones, enumeración).

Destacan el uso de software obsoleto, la exposición de directorios, la habilitación de métodos HTTP inseguros y la falta de cabeceras de seguridad. Además, la presencia de herramientas administrativas como phpMyAdmin y la exposición del endpoint /server-status incrementan significativamente el riesgo de compromiso del sistema.

DIRECTORIOS Y ARCHIVOS ENCONTRADOS

Fuerza bruta en directorios y archivos:

Resultados de gobuster y dirb:

- Enumeración de contenido web: gobuster, dirb

Gobuster / Dirb: Herramientas para localizar rutas ocultas o no indexadas (como /admin, /config) mediante el uso de diccionarios especializados.

Para la enumeración de directorios y archivos se utilizó el diccionario common.txt, ubicado en la ruta /usr/share/wordlists/dirb/. Este diccionario contiene una lista de nombres comunes de archivos y directorios utilizados en aplicaciones web, permitiendo identificar recursos ocultos o no documentados en el servidor.

El uso de este diccionario permitió identificar múltiples rutas relevantes como /phpmyadmin, /webdav y /drupal. Para un análisis más exhaustivo, se podrían utilizar diccionarios más completos como los incluidos en SecLists.

SecLists: Repositorio de diccionarios de Daniel Miessler que proporciona las listas de palabras necesarias para que las herramientas de fuerza bruta sean efectivas.

Nota: Dada la imposibilidad de actualización de mi máquina virtual Kali Linux, procedí a sustituir el diccionario SecLists por el existente en /usr/share/dirb/wordlists/dirb/

```bash
gobuster dir -u http://192.168.1.50 -w /usr/share/wordlists/dirb/common.txt
```

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.1.50 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://192.168.1.50
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 374]
.htaccess            (Status: 403) [Size: 379]
.htpasswd            (Status: 403) [Size: 379]
crossdomain.xml      (Status: 200) [Size: 200]
crossdomain          (Status: 200) [Size: 200]
drupal               (Status: 301) [Size: 403]  [--> http://192.168.1.50/drupal/]
evil                 (Status: 301) [Size: 401]  [--> http://192.168.1.50/evil/]
index                (Status: 200) [Size: 45]
index.html           (Status: 200) [Size: 588]
phpmyadmin           (Status: 301) [Size: 407]  [--> http://192.168.1.50/phpmyadmin/]
README               (Status: 200) [Size: 2491]
server-status        (Status: 200) [Size: 5784]
webdav               (Status: 301) [Size: 403]  [--> http://192.168.1.50/webdav/]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

La enumeración de directorios permitió identificar múltiples rutas críticas accesibles en el servidor, incluyendo paneles administrativos, servicios potencialmente explotables como WebDAV, y endpoints de información como /server-status. Estos hallazgos incrementan significativamente la superficie de ataque y proporcionan múltiples vectores para fases posteriores de explotación.

Análisis de enumeración de directorios encontrados:

Ruta	Código	Interpretación
/.hta, /.htaccess, /.htpasswd	403	Archivos sensibles protegidos
/crossdomain.xml	200	Archivo accesible
/drupal	301	CMS detectado
/evil	301	Directorio sospechoso
/phpmyadmin	301	Panel de BD
/server-status	200	Info del servidor
/webdav	301	Servicio WebDAV
/README	200	Archivo informativo

Hallazgos importantes:

/phpmyadmin: Panel de BD expuesto (crítico)
Riesgo de acceso a la base de datos, ataques de fuerza bruta, SQL Injection. Se identificó el panel phpMyAdmin accesible públicamente, lo que representa un riesgo crítico si no se encuentra debidamente protegido.

/server-status: Info del servidor accesible (crítico)
Riesgo de acceso a la información interna del servidor, peticiones activas y rutas internas (todo ello ya confirmado anteriormente con nikto).

/webdav: Servicio WebDAV habilitado
Riesgo de subida de archivos maliciosos, posible web shell.

/drupal: CMS detectado
CMS conocido con muchas vulnerabilidades. Riesgo:Exploits públicos, mala configuración.

evil: Directorio sospechoso detecado
Riesgo de vulnerabilidades (intencionadas).

/.hta, /.htaccess, /.htpasswd: Archivos sensibles protegidos detectados.
No están accesibles (403) aunque indican existencia de mecanismos de autenticación.

/crossdomain.xml: Archivo accesible
Riesgo que permite acceso entre dominios (CORS mal configurado).

/README: Archivo informativo accesible
Riesgo de filtración de información.

```bash
dirb http://192.168.1.50 /usr/share/wordlists/dirb/common.txt
```

```
┌──(kali㉿kali)-[~]
└─$ dirb http://192.168.1.50 /usr/share/wordlists/dirb/common.txt

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Mon Apr  6 10:05:51 2026
URL_BASE: http://192.168.1.50/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

-----------------

GENERATED WORDS: 4612
```

```
---- Scanning URL: http://192.168.1.50/ ----
+ http://192.168.1.50/crossdomain (CODE:200|SIZE:200)
+ http://192.168.1.50/crossdomain.xml (CODE:200|SIZE:200)
==> DIRECTORY: http://192.168.1.50/drupal/
==> DIRECTORY: http://192.168.1.50/evil/
+ http://192.168.1.50/index (CODE:200|SIZE:45)
+ http://192.168.1.50/index.html (CODE:200|SIZE:588)
==> DIRECTORY: http://192.168.1.50/phpmyadmin/
+ http://192.168.1.50/README (CODE:200|SIZE:2491)
+ http://192.168.1.50/server-status (CODE:200|SIZE:5922)
==> DIRECTORY: http://192.168.1.50/webdav/

---- Entering directory: http://192.168.1.50/drupal/ ----
+ http://192.168.1.50/drupal/cron (CODE:403|SIZE:7455)
==> DIRECTORY: http://192.168.1.50/drupal/includes/
+ http://192.168.1.50/drupal/index.php (CODE:200|SIZE:7779)
+ http://192.168.1.50/drupal/install (CODE:200|SIZE:3418)
+ http://192.168.1.50/drupal/LICENSE (CODE:200|SIZE:18092)
==> DIRECTORY: http://192.168.1.50/drupal/misc/
==> DIRECTORY: http://192.168.1.50/drupal/modules/
==> DIRECTORY: http://192.168.1.50/drupal/profiles/
+ http://192.168.1.50/drupal/README (CODE:200|SIZE:5382)
+ http://192.168.1.50/drupal/robots (CODE:200|SIZE:1550)
+ http://192.168.1.50/drupal/robots.txt (CODE:200|SIZE:1550)
==> DIRECTORY: http://192.168.1.50/drupal/scripts/
==> DIRECTORY: http://192.168.1.50/drupal/sites/
==> DIRECTORY: http://192.168.1.50/drupal/themes/
+ http://192.168.1.50/drupal/update (CODE:403|SIZE:4289)
+ http://192.168.1.50/drupal/web.config (CODE:200|SIZE:2178)
+ http://192.168.1.50/drupal/xmlrpc (CODE:200|SIZE:42)
+ http://192.168.1.50/drupal/xmlrpc.php (CODE:200|SIZE:42)

---- Entering directory: http://192.168.1.50/evil/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/phpmyadmin/ ----
+ http://192.168.1.50/phpmyadmin/favicon.ico (CODE:200|SIZE:18902)
+ http://192.168.1.50/phpmyadmin/index.php (CODE:200|SIZE:8132)
==> DIRECTORY: http://192.168.1.50/phpmyadmin/js/
==> DIRECTORY: http://192.168.1.50/phpmyadmin/lang/
==> DIRECTORY: http://192.168.1.50/phpmyadmin/libraries/
+ http://192.168.1.50/phpmyadmin/phpinfo.php (CODE:200|SIZE:0)
==> DIRECTORY: http://192.168.1.50/phpmyadmin/scripts/
==> DIRECTORY: http://192.168.1.50/phpmyadmin/themes/

---- Entering directory: http://192.168.1.50/webdav/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/drupal/includes/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/drupal/misc/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/drupal/modules/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)
```

```
---- Entering directory: http://192.168.1.50/drupal/profiles/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/drupal/scripts/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/drupal/sites/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/drupal/themes/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/phpmyadmin/js/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/phpmyadmin/lang/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/phpmyadmin/libraries/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/phpmyadmin/scripts/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

---- Entering directory: http://192.168.1.50/phpmyadmin/themes/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
   (Use mode '-w' if you want to scan it anyway)

-----------------
END_TIME: Mon Apr  6 10:06:13 2026
DOWNLOADED: 13836 - FOUND: 20
```

Dirb confirma lo encontrado con Gobuster:

/phpmyadmin
/server-status
/drupal
/webdav
/evil
/README

Los resultados obtenidos con Dirb coinciden con los de Gobuster, validando la existencia de múltiples rutas críticas en el servidor.
La enumeración con Dirb permitió identificar una gran cantidad de directorios accesibles, muchos de ellos con directory listing habilitado. Esto expone la estructura interna del servidor y facilita la identificación de archivos sensibles. Además, se detectaron componentes críticos como phpMyAdmin, Drupal y WebDAV, todos ellos potencialmente vulnerables. La presencia de archivos como

phpinfo.php y endpoints como xmlrpc.php incrementa significativamente el riesgo de explotación.

Nuevos hallazgos importantes

WARNING: Directory IS LISTABLE: habilitado (crítico)
Aparece en:
/evil
/webdav
/drupal/*
/phpmyadmin/*
Riesgo de ver todos los archivos del servidor, descargar código fuente, encontrar credenciales.
Se detectó directory listing habilitado en múltiples directorios, lo que permite a un atacante visualizar y acceder directamente a archivos internos del servidor.

Drupal expuesto en profundidad: Estructura completa detectada:
/drupal/includes/
/drupal/modules/
/drupal/sites/
/drupal/themes/
/drupal/install (GRAVE): Posible reinstalación del sistema
Riesgo de enumeración completa del CMS, ataques conocidos a Drupal

xmlrpc.php: accesible
/drupal/xmlrpc.php
Riesgo de ataques de fuerza bruta, DDDoS, ejecución remota en algunos casos.

phpinfo: expuesto (CRÍTICO)
/phpmyadmin/phpinfo.php
Riesgo MUY grave ya que muestra configuración del servidor, rutas internas, versiones exactas
La exposición de phpinfo.php permite obtener información detallada del entorno del servidor, facilitando ataques dirigidos.

Directorio /evil: LISTABLE
/evil
Riesgoulnerabilidades listas para explotar.

WebDAV: LISTABLE
/webdav
Riesgo doble por la posibilidad de ver archivos y subir archivos (posible shell)

Archivos interesantes
/drupal/README
/drupal/LICENSE
/drupal/web.config
Riesgo de filtración de información del sistema.

ANÁLISIS Y CONCLUSIONES

Discusión sobre los hallazgos más relevantes:

Se realizó reconocimiento sobre el objetivo identificado durante el barrido de red.

Durante la fase de reconocimiento se identificó que la máquina objetivo presenta una superficie de ataque amplia, caracterizada por la exposición de múltiples servicios, presencia de software obsoleto y configuraciones inseguras en el servicio web (métodos HTTP riesgosos, fuga de información y directorios sensibles accesibles).

El escaneo de puertos reveló numerosos servicios activos, incluyendo HTTP, FTP, SSH, SMB, MySQL y VNC, muchos de ellos ejecutándose en versiones obsoletas y vulnerables. Destaca especialmente el servidor web Apache junto con PHP, ambos en versiones antiguas sin soporte, lo que implica la existencia de vulnerabilidades conocidas y explotables.

El análisis con Nikto evidenció múltiples problemas de seguridad, como:

Uso de software desactualizado
Falta de cabeceras de seguridad
Métodos HTTP inseguros (TRACE)
Exposición de recursos sensibles como /server-status

Por otro lado, la enumeración de directorios mediante Gobuster y Dirb permitió identificar rutas críticas accesibles, tales como /phpmyadmin, /webdav, /drupal y /evil.

Además, se detectaron configuraciones especialmente peligrosas:

Directory listing habilitado en múltiples rutas.
Exposición de archivos como phpinfo.php.
Acceso a paneles administrativos sin restricciones.
Presencia de servicios potencialmente explotables como WebDAV.

En conjunto, estos hallazgos indican una configuración débil del sistema, con múltiples vectores de ataque disponibles para un atacante.

Identificación de posibles vectores de ataque para la siguiente fase del pentesting:

A partir de los resultados obtenidos, se identifican varios vectores de ataque relevantes que podrían ser explotados en la siguiente fase del pentesting:

Acceso a servicios expuestos:

FTP (puerto 21) → posible acceso anónimo o credenciales débiles.
SSH (puerto 22) → ataques de fuerza bruta.
MySQL (puerto 3306) → acceso remoto a base de datos.

Ataques sobre el servidor web:

- Explotación de Apache y PHP desactualizados.
- Ataques XSS debido a la ausencia de cabeceras de seguridad.
- Ataques XST por método HTTP TRACE habilitado.

Enumeración avanzada y fuga de información:

- /server-status → información interna del servidor.
- phpinfo.php → configuración detallada del sistema.
- Archivos README → filtración de información.

Acceso a recursos críticos:

- /phpmyadmin → ataque de credenciales o explotación directa.
- /drupal → explotación de vulnerabilidades del CMS.
- /evil → posibles vulnerabilidades intencionadas del laboratorio.

Subida de archivos maliciosos:

WebDAV (/webdav) → posible subida de web shells.

Exposición de estructura interna:

- Directory listing → acceso a archivos internos.
- Archivos .bak o configuraciones → posible filtración de credenciales.

Conclusión final

El sistema analizado presenta múltiples vulnerabilidades críticas derivadas de configuraciones inseguras y software obsoleto. La combinación de servicios expuestos, falta de controles de seguridad y acceso a recursos sensibles lo convierten en un objetivo altamente vulnerable.

Los resultados obtenidos en esta fase de reconocimiento proporcionan una base sólida para continuar con la fase de explotación, donde varios de los vectores identificados podrían ser utilizados para comprometer el sistema.